Luxury Times — Next.js Upgrade Report

May 2026

Headline Result: Vulnerabilities reduced from 21 (1 critical, 12 high, 8 moderate) to 0

OVERVIEW

The Luxury Times frontend was upgraded from Next.js 14.2.35 to Next.js 16.2.6 across three staged pull requests, with the primary goal of patching all known security vulnerabilities in the dependency tree. The work was carried out on a feature-branch-per-stage basis to keep each PR's diff focused, reviewable, and individually revertible.

Scope of Changes

Item	Before	After
Next.js	14.2.35	16.2.6
React / React DOM	^18	^19.2.6
ESLint	^8.57.1	^9.39.4
eslint-config-next	^14.2.3	^16.2.6
@next/third-parties	^14.2.3	^16.2.6
axios	^1.7.2	^1.16.1
swiper	^8.4.7	^12.1.4
Node engines floor	>=18.17.0	>=18.18.0
Middleware file convention	middleware.js	proxy.js
Total vulnerabilities	**21**	**0**

Approach

The upgrade was split into three discrete stages, each delivered as a separate pull request on its own feature branch. This protected main from a single large, hard-to-review change set and made each layer of risk independently revertible. Every stage followed the same pattern: install dependencies, apply codemods or manual edits, run a production build, smoke-test routes, then commit and push.

STAGE 1 — Next.js 14 → 15 + React 18 → 19

PR #7 · branch: chore/upgrade-next-16 · commit 24607bb

This was the highest-risk stage. The Next.js 14→15 boundary introduces the largest set of breaking changes, including the conversion of server component params and searchParams props from synchronous objects to Promises, alongside a forced upgrade to React 19.

Dependencies Upgraded

- next: 14.2.35 → 15.5.18
- react / react-dom: ^18 → ^19.2.6
- eslint-config-next: ^14.2.3 → ^15.5.18
- @next/third-parties: ^14.2.3 → ^15.5.18
- Node engines floor raised from >=18.17.0 to >=18.18.0

Codemod Applied

The official @next/codemod next-async-request-api was run across the codebase, transforming params and searchParams to await patterns in all server components. Seven files were modified, zero errors reported:

- app/blog/[handle]/page.jsx
- app/products/[handle]/page.jsx
- app/products/page.jsx
- app/products/collections/rolex/page.jsx
- app/products/collections/patek-philippe/page.jsx
- app/products/collections/audemars-piguet/page.jsx
- app/products/collections/richard-mille/page.jsx

Verification

npm run build succeeded with all 28 pages generated. Programmatic HTTP smoke tests against the home page, the daytona-116520 landing page, the products and blog listings, a real product detail page, a real blog article, the contact route, and the ?model=Daytona deep-link filter all returned 200. A manual browser QA pass was completed before merging.

Vulnerability count after stage: 21 → 16

STAGE 2 — Next.js 15 → 16

PR #8 · branch: chore/upgrade-next-16 · commit f47a172

This stage moved onto the current Next.js major (16.x), which npm audit identified as the target needed to clear all Next-related advisories.

Dependencies Upgraded

- next: 15.5.18 → 16.2.6
- eslint-config-next: ^15.5.18 → ^16.2.6
- @next/third-parties: ^15.5.18 → ^16.2.6
- eslint: ^8.57.1 → ^9.39.4 (required by eslint-config-next@16's peer dependency)

Configuration Changes

next.config.js now declares the set of allowed next/image quality values (mandatory in Next 16 wherever a non-default quality is used):

```
images: { qualities: [75, 80, 85, 90, 100], remotePatterns: [ cdn.shopify.com, shopifycdn.net ] }
```

File rename: Next 16 deprecated middleware.js in favour of proxy.js. The file was renamed via git mv to preserve history, and the exported function renamed from middleware to proxy. No behavioural change — JWT verification, protected paths, and route matcher are identical.

Verification

npm run build succeeded under Next.js 16's new default Turbopack builder, completing in approximately 12 seconds. Full smoke-test suite re-run and passed. Auth proxy verified against /admin and /dashboard.

Vulnerability count after stage: 16 → 14

STAGE 3 — Vulnerability Cleanup (axios, swiper, transitives)

PR #9 · branch: chore/upgrade-vuln-cleanup · commit 9a51356

This stage cleared the remaining 14 vulnerabilities, none of which were Next.js-related.

Direct Dependencies Upgraded

- axios ^1.7.2 → ^1.16.1 — clears 17 individual advisories covering SSRF, prototype pollution, CRLF injection, header injection, XSRF token leakage, DoS, and null byte injection.
- swiper ^8.4.7 → ^12.1.4 — clears a critical-severity prototype pollution advisory (GHSA-hmx5-qpq5-p643). Import path updated in FeaturedProducts.jsx and app/jewellery/Rings/page.js from 'swiper' to 'swiper/modules'.

Transitive Dependency Overrides

Some vulnerabilities lived in transitive dependencies whose parent packages had not yet released fixes. These were pinned via npm overrides in package.json:

```
"overrides": { "postcss": "^8.5.15", "tar": "^7.5.15" }
```

- tar ^7.5.15 — clears six advisories in the bcrypt → @mapbox/node-pre-gyp → tar chain (path traversal, symlink poisoning, arbitrary file read/write).
- postcss ^8.5.15 — clears XSS via unescaped advisory.
- npm audit fix — cleared remaining transitives: brace-expansion, follow-redirects, picomatch, uuid, and ws.

Verification

npm run build succeeded. Smoke tests targeted both Swiper-bearing routes (/jewellery/Rings and a real product detail page with FeaturedProducts carousel) alongside the standard route set — all returned 200. Manual browser QA confirmed slide animation, drag-to-scroll, and custom navigation buttons functioned correctly.

Vulnerability count after stage: 14 → 0

Vulnerability Reduction Summary

Stage	Direct Deps Changed	Vulnerabilities Remaining
Baseline (pre-upgrade)	—	21 (1 critical, 12 high, 8 moderate)
Stage 1 Next 14→15 + React 19	next, react, react-dom, eslint-config-next, @next/third-parties	16
Stage 2 Next 15→16	next, eslint-config-next, @next/third-parties, eslint	14
Stage 3 **axios, swiper, transitives**	**axios, swiper + overrides**	**0 ✓**

Risk Management & Rollback Strategy

Each stage was delivered as a self-contained pull request, allowing any individual stage to be reverted in isolation if a regression surfaced in production.

- No commits were made directly to main — every change passed through a PR for review.
- The official Next.js codemod was used for the highest-impact transformation (async params/searchParams), reducing the chance of human error compared to manual edits.

Known Follow-ups (Out of Scope)

These items pre-existed the upgrade and were intentionally left out of scope to keep diffs focused on vulnerability remediation:

- metadataBase warning in app/layout.js — a one-line fix to set the canonical base URL for Open Graph and Twitter card image resolution.
- eslint-config 'prettier' failure during npm run lint — needs eslint-config-prettier either installed as a devDependency or removed from .eslintrc.json.
- @supabase/auth-helpers-nextjs is deprecated upstream in favour of @supabase/ssr — migration recommended but not urgent.

OUTCOME

The application now runs on the latest stable Next.js major with all known dependency vulnerabilities patched. The architectural shape of the project — App Router server components, file-based routing, the Shopify Storefront GraphQL integration, the JWT-protected admin proxy, the Resend transactional email pipeline, Google Analytics tracking, and all UI behaviour — was preserved exactly as before. No business logic was changed; the upgrade was purely a platform and security exercise.